

REPORT TECNICO DI SICUREZZA

Implementazione e Verifica della Gestione dei Gruppi Utente

Windows Server 2022 – Active Directory

Autore: Leonardo Onori

Corso: Cybersecurity and Ethical Hacking – Epicode

Data: 31 Agosto 2026

Ambiente target: Windows Server 2022 (Domain Controller, dominio Epicode.local)

Classificazione: Uso didattico / Interno

EXECUTIVE SUMMARY

Il presente report documenta l'attività di hardening organizzativo condotta su un Domain Controller Windows Server 2022, tramite la creazione di gruppi di sicurezza dedicati e l'assegnazione di permessi differenziati secondo il principio del minimo privilegio (Principle of Least Privilege, PoLP).

Sono stati creati due gruppi di sicurezza — G_Marketing e G_Sviluppatori — a cui sono stati associati permessi distinti su risorse file, esecuzione applicativa e accesso remoto (RDP). La configurazione è stata validata sia lato server (verifica documentale delle ACL e delle membership) sia lato client, tramite test operativi eseguiti da una macchina Windows 10 aggiunta al dominio con due utenti dimostrativi (TestMarketing e TestSviluppo). Tutti i controlli pianificati sono risultati conformi alle aspettative attese.

SCOPE (AMBITO)

In scope:

- Creazione e standardizzazione di due gruppi di sicurezza in Active Directory
- Assegnazione di permessi granulari su cartelle condivise, esecuzione programmi e accesso remoto (RDP)
- Provisioning e test di utenti dimostrativi
- Verifica delle ACL tramite strumenti nativi (icacls, cmdlet AD)
- Validazione end-to-end da un client Windows 10 unito al dominio

Out of scope:

- Hardening avanzato del Domain Controller (patching, GPO di sicurezza avanzate, auditing)
- Configurazione di Fine-Grained Password Policy
- Test di penetrazione o simulazione di attacco reale

METHODOLOGY (METODOLOGIA)

L'attività è stata condotta tramite console amministrativa PowerShell, applicando una convenzione di naming rigida senza spazi (G_Marketing, G_Sviluppatori) per prevenire errori di parsing e garantire l'interoperabilità con script di automazione.

Fasi operative:

1. **Ricognizione ambiente:** identificazione del contesto (DC nel dominio Epcode.local) tramite whoami e systeminfo
2. **Provisioning gruppi:** creazione dei gruppi di sicurezza tramite il modulo ActiveDirectory (New-ADGroup)
3. **Hardening dei permessi:** applicazione di ACL NTFS granulari (icacls), rimozione dell'ereditarietà di default e assegnazione del Deny Esplicito
4. **Configurazione condivisioni SMB:** creazione delle share di rete e allineamento dei permessi di condivisione con le ACL NTFS
5. **Provisioning utenti di test** e associazione ai gruppi
6. **Validazione da client:** esecuzione dei test di accesso reali da una workstation Windows 10 unita al dominio
7. **Configurazione dell'accesso RDP** al Domain Controller per il gruppo G_Sviluppatori, tramite modifica della Default Domain Controllers Policy

FINDINGS (RISULTATI)

```
PS C:\Users\Administrator> systeminfo | Select-String "Domain:"
Domain:                                Epcode.local
```

4.1 Asset creati

```
PS C:\Users\Administrator> New-ADGroup -Name "G_Marketing" -GroupScope Global -GroupCategory Security -Path "CN=Users,DC=Epcode,DC=local" -Description "Gruppo utenti reparto Marketing"
PS C:\Users\Administrator> New-ADGroup -Name "G_Sviluppatori" -GroupScope Global -GroupCategory Security -Path "CN=Users,DC=Epcode,DC=local" -Description "Gruppo sviluppatori software"
```

ID	Gruppo	Categoria	Scope	Funzione
G-01	G_Marketing	Security	Global	Reparto Marketing
G-02	G_Sviluppatori	Security	Global	Team Sviluppo

Comando di verifica ed esito:

PS C:\Users\Administrator> Get-ADGroup -Filter "Name -like 'G_*'" | Select-Object Name, GroupCategory, GroupScope

```

Name          GroupCategory GroupScope
----          -
G_Marketing    Security      Global
G_Sviluppatori Security      Global

```

Name	GroupCategory	GroupScope
----	-----	-----
G_Marketing	Security	Global
G_Sviluppatori	Security	Global

4.2 Matrice dei permessi assegnati

Risorsa	G_Marketing	G_Sviluppatori	Motivazione tecnica
C:\Condivise\Marketing	Modify (OI)(CI)	Nessun accesso	Accesso esclusivo al reparto proprietario del dato
C:\Condivise\Sviluppo	Nessun accesso	Modify (OI)(CI)	Isolamento dei repository di sviluppo
C:\Program Files\ToolSviluppo	DENY esplicito (RX)	Read & Execute (RX)	Il Deny esplicito ha priorità assoluta su eventuali permessi ereditati futuri
Accesso remoto (RDP)	Negato	Consentito	Il gruppo G_Sviluppatori è membro del gruppo Builtin Remote Desktop Users e autorizzato nella Default Domain Controllers Policy

Verifica ACL NTFS:

```
C:\Condivise\Marketing EPICODE\G_Marketing:(OI)(CI)(M)
                        EPICODE\Domain Admins:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Condivise\Sviluppo EPICODE\G_Sviluppatori:(OI)(CI)(M)
                      EPICODE\Domain Admins:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Program Files\ToolSviluppo EPICODE\G_Marketing:(OI)(CI)(DENY)(RX)
                              EPICODE\G_Sviluppatori:(OI)(CI)(RX)
                              EPICODE\Domain Admins:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
```

Nota tecnica – Permessi di condivisione SMB: durante la validazione da client è emerso che il livello di permesso "Share" (di default più restrittivo di quello NTFS su nuove condivisioni) impediva la scrittura anche dove le ACL NTFS lo avrebbero consentito. È stato quindi allineato il permesso di condivisione a Full Control per Everyone, lasciando l'effettivo controllo di sicurezza alle sole ACL NTFS (best practice comune: "NTFS governa, la Share non deve essere il collo di bottiglia").

4.3 Configurazione dell'accesso RDP al Domain Controller

Poiché i Domain Controller applicano restrizioni più severe rispetto ai server membri standard, il solo inserimento del gruppo nel gruppo Remote Desktop Users non è sufficiente: è necessario che il diritto "Consentire accesso tramite Servizi Desktop Remoto" (SeRemoteInteractiveLogonRight) sia esplicitamente definito nella Default Domain Controllers Policy.

Passaggi eseguiti:

1. Aggiunta del gruppo G_Sviluppatori al gruppo Builtin locale RDP (SID S-1-5-32-555) tramite Add-ADGroupMember
2. Verifica ed aggiornamento della Default Domain Controllers Policy (assegnazione diritti utente > Consentire accesso tramite Servizi Desktop Remoto)
3. Sincronizzazione della versione GPO tra Active Directory e SYSVOL e forzatura dell'aggiornamento tramite gpupdate /force
4. Verifica della porta 3389 dal client con Test-NetConnection

```
PS C:\Users\Administrator> Get-ADGroupMember -Identity "S-1-5-32-555" | Select-Object Name, SamAccountName, SID
```

```
Name          SamAccountName  SID
----          -
G_Sviluppatori G_Sviluppatori  S-1-5-21-288451266-2587220724-887712270-1121
```

```
PS C:\Users\TestSviluppo.EPICODE> Test-NetConnection -ComputerName 192.168.50.10 -Port 3389
```

```
ComputerName    : 192.168.50.10
RemoteAddress    : 192.168.50.10
RemotePort       : 3389
TcpTestSucceeded : True
```

```
PS C:\Users\Administrator> Get-ADGroupMember -Identity "S-1-5-32-555" | Select-Object Name, SamAccountName, SID

Name          SamAccountName SID
----          -
G_Sviluppatori G_Sviluppatori S-1-5-21-288451266-2587220724-887712270-1121

PS C:\Users\Administrator> gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.
```

```
PS C:\Users\TestSviluppo.EPICODE> Test-NetConnection -ComputerName 192.168.50.10 -Port 3389

ComputerName    : 192.168.50.10
RemoteAddress    : 192.168.50.10
RemotePort       : 3389
InterfaceAlias   : Ethernet
SourceAddress    : 192.168.50.20
TcpTestSucceeded : True
```

4.4 Validazione tramite utenti di test

Utente	Gruppo appartenenza	Scopo
TestMarketing	G_Marketing	Validazione permessi reparto Marketing
TestSviluppo	G_Sviluppatori	Validazione permessi reparto Sviluppo

```

PS C:\Users\Administrator> Get-ADGroup -Filter "Name -like 'G_*'" | Select-Object Name, GroupCategory, GroupScope
>> Get-ADGroupMember -Identity "G_Marketing" | Select-Object Name, SamAccountName
>> Get-ADGroupMember -Identity "G_Sviluppatori" | Select-Object Name, SamAccountName
>> Get-ADGroupMember -Identity "Remote Desktop Users" | Select-Object Name
>> icacls "C:\Condivise\Marketing"
>> icacls "C:\Condivise\Sviluppo"
>> icacls "C:\Program Files\ToolSviluppo"

Name                GroupCategory GroupScope
-----
G_Marketing         Security      Global
G_Sviluppatori      Security      Global
Test Marketing
Test Sviluppo
G_Sviluppatori
C:\Condivise\Marketing EPICODE\G_Marketing:(OI)(CI)(M)
                        EPICODE\Domain Admins:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Condivise\Sviluppo EPICODE\G_Sviluppatori:(OI)(CI)(M)
                        EPICODE\Domain Admins:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Program Files\ToolSviluppo EPICODE\G_Marketing:(OI)(CI)(DENY)(RX)
                                EPICODE\G_Sviluppatori:(OI)(CI)(RX)
                                EPICODE\Domain Admins:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files

```

4.5 Evidenza dei test di accesso da client Windows 10

Per convalidare l'effettiva applicazione delle regole in un contesto di rete reale, sono stati eseguiti i test di accesso da una workstation Windows 10 integrata nel dominio Epicode.local (IP client: 192.168.50.20, IP Domain Controller: 192.168.50.10).

Test ID	Account	Destinazione / Risorsa	Azione	Risultato Atteso	Risultato Effettivo	Stato
TC-01	TestMarketing	\192.168.50.10\Marketing	Scrittura file	Consentito	File creato con successo	PASS
TC-02	TestMarketing	\192.168.50.10\Sviluppo	Apertura cartella	Negato	Access is Denied	PASS
TC-03	TestMarketing	\192.168.50.10\ToolSviluppo	Lettura	Negato (Deny esplicito)	Access is Denied	PASS
TC-04	TestMarketing	Domain Controller	Sessione RDP	Rifiutata	Rifiutata	PASS
TC-05	TestSviluppo	\192.168.50.10\Marketing	Apertura cartella	Negato	Access is Denied	PASS
TC-06	TestSviluppo	\192.168.50.10\Sviluppo	Scrittura file	Consentito	File creato con successo	PASS
TC-07	TestSviluppo	\192.168.50.10\ToolSviluppo	Lettura	Consentito	Lettura eseguita con successo	PASS
TC-08	TestSviluppo	Domain Controller	Sessione RDP	Consentita	Sessione avviata con successo	PASS

Output rappresentativo (utente TestMarketing):

```
PS C:\Users\TestMarketing> New-Item -Path "\\192.168.50.10\Marketing\test_mkt_clean.txt" -ItemType File

Directory: \\192.168.50.10\Marketing

Mode                LastWriteTime         Length Name
----                -
-a----           31/08/2026    11:39             0 test_mkt_clean.txt

PS C:\Users\TestMarketing> Get-ChildItem -Path "\\192.168.50.10\Sviluppo"
Get-ChildItem : Accesso al percorso '\\192.168.50.10\Sviluppo' negato.
In riga:1 car:1
+ Get-ChildItem -Path "\\192.168.50.10\Sviluppo"
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (\\192.168.50.10\Sviluppo:String) [Get-ChildItem], UnauthorizedAccessE
  xception
+ FullyQualifiedErrorId : DirUnauthorizedAccessError,Microsoft.PowerShell.Commands.GetChildItemCommand

PS C:\Users\TestMarketing> Get-ChildItem -Path "\\192.168.50.10\ToolSviluppo"
Get-ChildItem : Accesso al percorso '\\192.168.50.10\ToolSviluppo' negato.
In riga:1 car:1
+ Get-ChildItem -Path "\\192.168.50.10\ToolSviluppo"
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (\\192.168.50.10\ToolSviluppo:String) [Get-ChildItem], UnauthorizedAcc
  essException
+ FullyQualifiedErrorId : DirUnauthorizedAccessError,Microsoft.PowerShell.Commands.GetChildItemCommand

PS C:\Users\TestMarketing> mstsc /v:192.168.50.10
PS C:\Users\TestMarketing>
```

Connessione Desktop remoto

Impossibile connettere Remote Desktop al computer remoto per uno dei motivi seguenti:

- 1) L'accesso remoto al server non è abilitato.
- 2) Il computer remoto è spento.
- 3) Il computer remoto non è disponibile in rete.

Verifica che il computer remoto sia acceso e connesso alla rete e che l'accesso remoto sia abilitato.

Output rappresentativo (utente TestSviluppo):

```
PS C:\Users\TestSviluppo.EPICODE> Get-ChildItem -Path "\\192.168.50.10\Marketing"
Get-ChildItem : Accesso al percorso '\\192.168.50.10\Marketing' negato.
In riga:1 car:1
+ Get-ChildItem -Path "\\192.168.50.10\Marketing"
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (\\192.168.50.10\Marketing:String) [Get-ChildItem], UnauthorizedAccess
  Exception
+ FullyQualifiedErrorId : DirUnauthorizedAccessError,Microsoft.PowerShell.Commands.GetChildItemCommand

PS C:\Users\TestSviluppo.EPICODE> New-Item -Path "\\192.168.50.10\Sviluppo\test_dev_clean.txt" -ItemType File -Force

Directory: \\192.168.50.10\Sviluppo

Mode                LastWriteTime         Length Name
----                -
-a----           31/08/2026    12:28             0 test_dev_clean.txt

PS C:\Users\TestSviluppo.EPICODE> Get-ChildItem -Path "\\192.168.50.10\ToolSviluppo"
PS C:\Users\TestSviluppo.EPICODE> mstsc /v:192.168.50.10
```

192.168.50.10 - Connessione Desktop remoto

Nota di sicurezza sul logon locale sul Domain Controller: durante le verifiche, il tentativo di logon interattivo diretto sulla console del Domain Controller con un utente non privilegiato viene bloccato. Questo comportamento non costituisce un errore, ma un meccanismo di sicurezza nativo di Active Directory (Default Domain Controllers Policy) che impedisce ad account non privilegiati di autenticarsi fisicamente su un nodo critico dell'infrastruttura. Per questo motivo, l'accesso RDP concesso a G_Sviluppatori è stato configurato in modo puntuale e documentato, e non esteso ad altri gruppi.

RISK ASSESSMENT (VALUTAZIONE DEL RISCHIO)

Rischio potenziale	Rischio potenziale	Rischio potenziale	Rischio potenziale
Accesso incrociato tra reparti a dati sensibili	Alto	Media	Segregazione NTFS con rimozione ereditarietà (/inheritance:r)
Esecuzione non autorizzata di tool di sviluppo	Medio	Media	Deny esplicito su ToolSviluppo per G_Marketing
Privilege escalation via gruppi operativi	Alto	Bassa	Nessuna membership dei gruppi in Domain Admins o Administrators
Accesso remoto non autorizzato al server	Alto	Media	RDP limitato al solo gruppo G_Sviluppatori, autorizzato esplicitamente in GPO
Permessi di condivisione SMB troppo permissivi (Everyone: Full)	Medio	Bassa	Mitigato dalle ACL NTFS più restrittive, che restano il controllo di sicurezza effettivo

RECOMMENDATIONS (RACCOMANDAZIONI)

Per ambienti di produzione si consiglia di estendere l'architettura con:

1. Applicazione di GPO dedicate (non la Default Domain Controllers Policy) per la gestione dei diritti di logon, per non alterare le policy di default
2. Restrizione dei permessi di condivisione SMB a livello di singolo gruppo, invece di Everyone: Full, per ridurre la superficie di attacco a livello di rete
3. Abilitazione dell'auditing avanzato del file system (Event ID 4663) sulle condivisioni
4. Revisione periodica delle membership AD (access recertification)
5. Adozione del modello AGDLP per architetture multi-dominio complesse

CONCLUSION (CONCLUSIONI)

L'attività ha consentito di implementare una segregazione granulare dei privilegi in ambiente Active Directory conforme al principio del minimo privilegio, e di validarla concretamente da un client di dominio reale. Tutti i controlli pianificati sono stati eseguiti e verificati con successo end-to-end, includendo la risoluzione di problematiche operative reali incontrate durante il collaudo (permessi di condivisione SMB, propagazione della GPO per l'accesso RDP sul Domain Controller), documentate nel presente report a dimostrazione del processo di troubleshooting seguito.